

Security+ 5.2 · Risk Analysis

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.2 — Risk Analysis (9:13)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Risk analysis can be qualitative (high/medium/low) or quantitative (monetary — $SLE \times ARO = ALE$). Risk appetite is the level of risk the organization is willing to accept (defined by the board). Risk tolerance is the acceptable variation per business unit. The risk register documents all identified risks.

High-Yield Core Concepts Tested on Exam

- $ALE = SLE$ (loss per incident) $\times$ ARO (times per year) — quantitative
- Risk appetite: the risk level the organization accepts (board-defined)
- Risk tolerance: acceptable variation per area (operational)
- Qualitative analysis uses subjective ratings (high/medium/low)
- Risk register: central repository for risks, owners, and responses

Exam Tips & Classic Scenarios

- 'accepting a specific risk level per business unit' = risk tolerance
- 'overall risk the organization is willing to accept' = risk appetite
- ' $SLE \times ARO$ ' = ALE
- 'loss per incident' = SLE
- 'times per year' = ARO

Typical Exam Scenario: A company estimates a \$500k loss per incident and expects 2 incidents per year. The ALE is \$1M/year. This is a quantitative analysis. The exam may ask to calculate ALE or identify the type of analysis.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.2 — Risk Analysis)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. RTO (Recovery Time Objective) measures:

- A)** How much DATA you accept losing
- B)** How much TIME the service can be down
- C)** The cost of the incident
- D)** The number of affected users

2. Corporate scenario (Risk Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'ALE = SLE (loss per incident) × ARO (times/year) — the quantitative one'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: ALE = SLE (loss per incident) × ARO (times/year) — the quantitative one...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

3. Corporate scenario (Risk Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'Appetite: the RISK it accepts; tolerance: variation per area (operational)'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Appetite: the RISK it accepts; tolerance: variation per area (operational)...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Risk Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'accepting a specific risk level per business unit'=risk tolerance'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'accepting a specific risk level per business unit'=risk tolerance...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Risk Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'loss per incident of \$500k x 2/year = ALE of \$1M/year' — quantitative.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'loss per incident of \$500k x 2/year = ALE of \$1M/year' — quantitative....

6. Corporate scenario (Risk Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'ALE = SLE (loss per incident) × ARO (times/year) — the quantitative one'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: ALE = SLE (loss per incident) × ARO (times/year) — the quantitative one...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Risk Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'Appetite: the RISK it accepts; tolerance: variation per area (operational)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Appetite: the RISK it accepts; tolerance: variation per area (operational)...

8. Corporate scenario (Risk Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'accepting a specific risk level per business unit' = risk tolerance. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'accepting a specific risk level per business unit' = risk tolerance...

9. Corporate scenario (Risk Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'loss per incident of \$500k x 2/year = ALE of \$1M/year' — quantitative.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'loss per incident of \$500k x 2/year = ALE of \$1M/year' — quantitative....
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Risk Analysis): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.2), an analyst evaluates the following technical requirement: 'ALE = SLE (loss per incident) × ARO (times/year) — the quantitative'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: $ALE = SLE \text{ (loss per incident)} \times ARO \text{ (times/year)}$ — the quantitative...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — How much TIME the service can be down.

✓ **Why it's correct:** The correct answer is: how much TIME the service can be down. RTO (Recovery Time Objective) is a central metric in the Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP), covered in the Business Continuity and Disaster Recovery domain of CompTIA Security+ SY0-701. It defines the maximum acceptable time to restore a service or process after an interruption, before the business impact becomes unacceptable. For example, if an e-commerce site sets an RTO of 2 hours, the recovery team must restore operations within 2 hours after the incident. RTO guides the choice of recovery strategies (hot site, warm site, cold site), backup frequency, and investments in redundancy. It is often confused with RPO, but while RTO measures downtime, RPO measures data loss.

✗ **Why the others are wrong:**

- *How much DATA you accept losing:* This is the definition of RPO (Recovery Point Objective), not RTO. RPO establishes the maximum amount of data that can be lost, measured in time (e.g., 15 minutes of transactions). It determines backup frequency: if the RPO is 1 hour, backups must occur at least every hour. RTO, on the other hand, focuses on service restoration time, not data loss. Confusing the two concepts leads to inadequate recovery strategies, as a low RPO does not guarantee a low RTO, and vice versa.
- *The cost of the incident:* The cost of the incident is a financial metric that quantifies direct and indirect losses resulting from an interruption (lost revenue, fines, productivity, reputational damage). Although it is an input to justify investments in continuity, it is not the definition of RTO. RTO is a time goal, not a monetary value. Using cost as the definition of RTO would divert focus from recovery planning, which needs clear temporal parameters to guide technical actions.
- *The number of affected users:* The number of affected users is an impact metric, useful for prioritization and communication, but it does not define RTO. RTO is a recovery time objective, regardless of the number of users. A service critical to few users may have a short RTO, while a service for many users may have a longer RTO, depending on business criticality. Therefore, this alternative does not correspond to the formal concept of RTO.

2) A — Implement the corresponding solution: $ALE = SLE \text{ (loss per incident)} \times ARO \text{ (times/year)}$ — the quantitative one....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Analysis): $ALE = SLE \text{ (loss per incident)} \times ARO \text{ (times/year)}$ — the quantitative one.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) A — Implement the corresponding solution: Appetite: the RISK it accepts; tolerance: variation per area (operational)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for

lesson 5.2 (Risk Analysis): Appetite: the RISK it accepts; tolerance: variation per area (operational). Risk appetite defines the level of risk an organization is willing to accept, while risk tolerance specifies acceptable deviations in operational areas.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: 'accepting a specific risk level per business unit' = risk tolerance....

✓ Why it's correct: According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Analysis): 'accepting a specific risk level per business unit' = risk tolerance. Risk tolerance refers to the acceptable variation in risk levels that an organization is willing to accept per business unit or process.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: 'loss per incident of \$500k x 2/year = ALE of \$1M/year' — quantitative.....

✓ Why it's correct: According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Analysis): 'loss per incident of \$500k x 2/year = ALE of \$1M/year' — quantitative.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: $ALE = SLE \text{ (loss per incident)} \times ARO \text{ (times/year)}$ — the quantitative one....

✅ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Analysis): $ALE = SLE \text{ (loss per incident)} \times ARO \text{ (times/year)}$ — the quantitative one. Annualized Loss Expectancy (ALE) is a quantitative risk metric calculated by multiplying the Single Loss Expectancy (SLE) by the Annualized Rate of Occurrence (ARO). It estimates the expected monetary loss from a risk over one year and is used to justify security investments.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: Appetite: the RISK it accepts; tolerance: variation per area (operational)....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Analysis): Appetite: the RISK it accepts; tolerance: variation per area (operational). Risk appetite is the amount of risk an organization is willing to accept, while risk tolerance is the acceptable deviation from that appetite in specific areas.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: 'accepting a specific risk level per business unit' = risk tolerance....

✅ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Analysis): 'accepting a specific risk level per business unit' = risk tolerance. Risk tolerance is the amount of risk an organization is willing to accept in pursuit of its objectives. It is often defined per business unit or department. The appropriate control is to implement the corresponding solution, which involves defining and documenting risk tolerance levels and ensuring they align with the overall risk appetite.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: 'loss per incident of \$500k x 2/year = ALE of \$1M/year' — quantitative.....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Analysis): 'loss per incident of \$500k x 2/year = ALE of \$1M/year' — quantitative. This correctly applies the quantitative risk analysis formula: Annualized Loss Expectancy (ALE) = Single Loss Expectancy (SLE) × Annualized Rate of Occurrence (ARO).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: ALE = SLE (loss per incident) × ARO (times/year) — the quantitative....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.2 (Risk Analysis): ALE = SLE (loss per incident) × ARO (times/year) — the quantitative. Annualized Loss Expectancy (ALE) is a quantitative risk assessment metric calculated by multiplying the Single Loss Expectancy (SLE) by the Annualized Rate of Occurrence (ARO). It helps organizations prioritize risks and justify security investments.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.